Universidad de la Sierra Sur
Licenciatura en Informática

MAPA VISUAL · PRIMER PARCIAL

Glosario de terminología y temas

Seguridad de Centros de Informática

ALUMNO Daniel González Ruiz
DOCENTE Dr. Arisaí Darío Barragán López
GRUPO 906
CICLO Ciclo Escolar 26-27A
ENTREGA 23 de octubre de 2026



6 temas
124 términos
29 relaciones

Cada tema es una rama del mapa; sus subtemas agrupan los términos y las líneas de colores conectan conceptos de distintos temas. Versión interactiva en 3D: glosario-beryl.vercel.app

VISTA GENERAL

Mapa de temas del primer parcial

Del centro salen los 6 temas; cada tema se divide en subtemas y las bandas internas muestran qué temas comparten conceptos.



01 **Tríada de la seguridad (CIA)** p. 3
Los tres objetivos que guían toda protección de la información · 2...
02 05 06

02 **Políticas de seguridad** p. 4
Reglas documentadas que dirigen la conducta de usuarios y pers...
01 03 04 05

03 **Análisis y evaluación del riesgo** p. 5
Identificar, medir y priorizar riesgos de forma cualitativa y cuantit...
02 06

04 **Estándares y marcos de seguridad** p. 6
Referencias reconocidas para organizar, medir y mejorar la segur...
02 05 06

05 **Prevención de pérdida de datos (DLP)** p. 7
Saber dónde está la información sensible y evitar que salga sin c...
01 02 04

06 **Análisis de impacto al negocio (BIA)** p. 8
Qué procesos son críticos y cuánto tiempo puede resistir la orga...
01 03 04

Tema → subtema

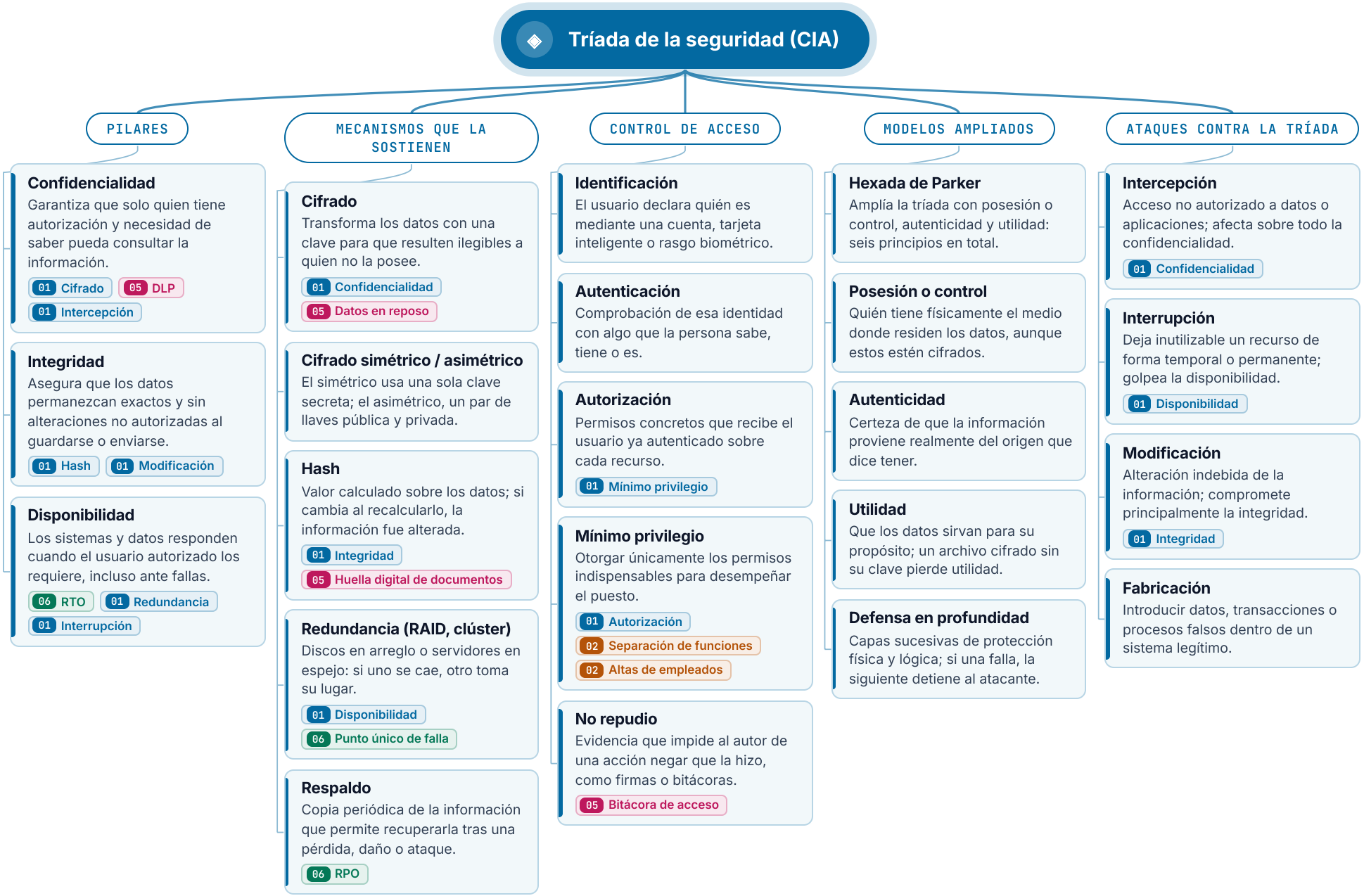
Conceptos compartidos (más grueso = más relaciones)

00 Tema relacionado

01 Tríada de la seguridad (CIA)

Los tres objetivos que guían toda protección de la información

22 términos · 5 subtemas
16 relaciones con 02 05 06



02 Políticas de seguridad

Reglas documentadas que dirigen la conducta de usuarios y personal de TI

22 términos · 5 subtemas
7 relaciones con 01 03 04 05



03 Análisis y evaluación del riesgo

Identificar, medir y priorizar riesgos de forma cualitativa y cuantitativa

22 términos · 5 subtemas
6 relaciones con 02 06



ELEMENTOS

Activo
Lo que vale la pena proteger porque su pérdida perjudica al negocio, sea tangible o intangible.

03 AV

Amenaza
Fuerza externa capaz de vulnerar los controles de seguridad de la organización.

Vulnerabilidad
Debilidad interna de los controles que una amenaza podría aprovechar.

03 Escaneo de vulnerabilidades

Riesgo
Surge cuando una amenaza coincide con una vulnerabilidad; si falta una de las dos, no existe.

```
Riesgo = Amenaza × Vulnerabilidad
```

02 Debida diligencia

Impacto
Magnitud del daño que sufre la organización si el riesgo llega a concretarse.

06 BIA

EVALUACIÓN CUALITATIVA

Evaluación cualitativa
Expertos juzgan probabilidad e impacto con escalas como alto, moderado y bajo.

Matriz de riesgos
Cuadro de probabilidad contra impacto que muestra a simple vista qué riesgos atender primero.

06 Priorización de procesos

Registro de riesgos
Bitácora donde cada área anota sus riesgos y tratamientos; se revisa cada año.

EVALUACIÓN CUANTITATIVA

Evaluación cuantitativa
Usa datos numéricos y monetarios para estimar la pérdida esperada de cada riesgo.

AV (valor del activo)
Costo en dinero de reemplazar o reconstruir el activo evaluado.

03 Activo

EF (factor de exposición)
Fracción, expresada en porcentaje, del valor del activo que destruiría un evento.

SLE (expectativa de pérdida única)
Cuánto dinero cuesta que el evento ocurra una vez.

```
SLE = AV × EF
```

ARO (tasa anual de ocurrencia)
Frecuencia esperada al año; una inundación por siglo se expresa como 0.01.

ALE (expectativa de pérdida anual)
Costo anual del riesgo; un control no debería costar más que lo que ahorra.

```
ALE = SLE × ARO
```

Ejemplo · sismo en el centro de datos

AV de $20 millones, EF de 50 % y ARO de 0.03.

```
SLE = $10 millones · ALE = $300,000 al año
```

TRATAMIENTO DEL RIESGO

Evitar
Cambiar la actividad del negocio para eliminar el riesgo, como reubicar un centro de datos.

Transferir
Trasladar el impacto económico a otra entidad mediante un seguro o una cláusula de indemnización.

Mitigación
Estrategia favorita en seguridad: poner firewalls, IPS u otros controles ligados directamente al riesgo.

02 Debido cuidado

Disuasión
Medidas que desaniman al atacante, como acciones legales firmes o vigilancia visible.

Aceptar
Solo vigilar el riesgo sin actuar, decisión válida únicamente tras un análisis que la justifique.

GESTIÓN DE VULNERABILIDADES

Escaneo de vulnerabilidades
Revisión no intrusiva que detecta debilidades conocidas sin explotarlas.

03 Vulnerabilidad

Prueba de penetración
Ataque autorizado y más intrusivo que intenta explotar las vulnerabilidades encontradas.

04 Estándares y marcos de seguridad

Referencias reconocidas para organizar, medir y mejorar la seguridad

19 términos · 4 subtemas
5 relaciones con 02 05 06



NIST CYBERSECURITY FRAMEWORK

NIST CSF
Marco voluntario de EE. UU. para gestionar el riesgo cibernético; su versión 1.0 es de 2014.

Núcleo del marco
Actividades y resultados organizados en funciones, categorías, subcategorías y referencias informativas.

Funciones del núcleo
Cinco actividades que se realizan en paralelo y de forma continua, no como pasos en serie.

`Identificar · Proteger · Detectar · Responder · Recuperar`

Niveles de implementación
Grado de madurez en la gestión del riesgo: parcial, informado, repetible y adaptativo.

Perfil actual y objetivo
Comparar dónde está la organización y dónde quiere llegar revela las brechas por cubrir.

CIS CONTROLS

CIS Controls v8.1
Conjunto priorizado de 18 controles con acciones concretas contra los ataques más comunes.

05 Proceso de gestión de datos

Salvaguarda
Acción específica y medible dentro de cada control CIS; antes se llamaba subcontrol.

Grupos de implementación (IG)
IG1, IG2 e IG3 priorizan salvaguardas según los recursos y el riesgo de cada empresa.

IG1: higiene cibernética esencial
Salvaguardas mínimas que toda organización debería aplicar contra los ataques frecuentes.

NORMAS ISO/IEC

ISO/IEC 27001
Estándar internacional cuyos requisitos permiten que una empresa audite y certifique su SGSI.

ISO/IEC 27002
Código de buenas prácticas con controles de seguridad; también orienta la clasificación de datos.

05 Clasificación de datos

SGSI
Sistema de gestión que asigna recursos y controles según el tipo y valor de cada clase de información.

ISO/IEC 38505-1
Aplica los principios de gobierno de TI de ISO 38500 al gobierno de los datos.

Modelo EDM
El órgano de gobierno evalúa, dirige y monitorea cómo se manejan y usan los datos.

Seis principios de gobierno
Responsabilidad, estrategia, adquisición, desempeño, conformidad y comportamiento humano.

LEYES Y REGULACIONES

HIPAA
Norma de EE. UU. que obliga a hospitales y aseguradoras a resguardar los expedientes de salud.

02 Política regulatoria

SOX
Ley Sarbanes-Oxley: exige controles y transparencia sobre la información financiera de empresas que cotizan en bolsa.

06 Impacto legal o regulatorio

GLBA
Ley Gramm-Leach-Bliley: obliga a las financieras a proteger datos de clientes y combate el pretexting.

Privacy Act (1974)
Ley que fija estándares para manejar la información personal en poder del gobierno federal.

05 PII

05 Prevención de pérdida de datos (DLP)

Saber dónde está la información sensible y evitar que salga sin control

20 términos · 5 subtemas
9 relaciones con 01 02 04



06 Análisis de impacto al negocio (BIA)

Qué procesos son críticos y cuánto tiempo puede resistir la organización sin ellos

19 términos · 5 subtemas
6 relaciones con 01 03 04



CONCEPTO

BIA
Análisis que identifica los procesos críticos y estima el daño que causa interrumpirlos con el paso del tiempo.
03 Impacto

Proceso crítico
Actividad sin la cual la organización no puede cumplir su misión ni generar ingresos.

Dependencias
Personas, sistemas, proveedores e instalaciones que un proceso necesita para operar.

Punto único de falla
Componente cuya caída detiene todo el proceso porque no tiene respaldo.
01 Redundancia

MÉTRICAS DE TIEMPO

MTD (tiempo máximo tolerable)
Lapso máximo de interrupción antes de que el daño resulte inaceptable.

RTO
Tiempo objetivo para restablecer un proceso; siempre debe ser menor que el MTD.
01 Disponibilidad

RPO
Cantidad máxima de datos, medida en tiempo, que se puede perder; marca la frecuencia de respaldos.
01 Respaldo

MTTR
Tiempo promedio que tarda en repararse un componente que falló.

MTBF
Tiempo promedio que opera un equipo entre una falla y la siguiente.

TIPOS DE IMPACTO

Impacto financiero
Ingresos perdidos, multas y costos adicionales provocados por la interrupción.

Impacto operativo
Retrasos, trabajo acumulado y pérdida de productividad mientras el proceso está detenido.

Impacto reputacional
Desconfianza de clientes y socios ante fallas visibles del servicio.

Impacto legal o regulatorio
Sanciones por incumplir contratos o leyes durante la interrupción.
04 SOX

ETAPAS DEL BIA

Recolección de información
Entrevistas y cuestionarios a los responsables de cada área sobre sus procesos.

Priorización de procesos
Ordenar los procesos según su impacto para decidir qué recuperar primero.
03 Matriz de riesgos

Informe BIA
Documento con hallazgos, tiempos y prioridades que la dirección revisa y aprueba.

RELACIÓN CON OTROS PLANES

BCP
Estrategia para que la empresa siga dando servicio durante una crisis; se diseña con los resultados del BIA.

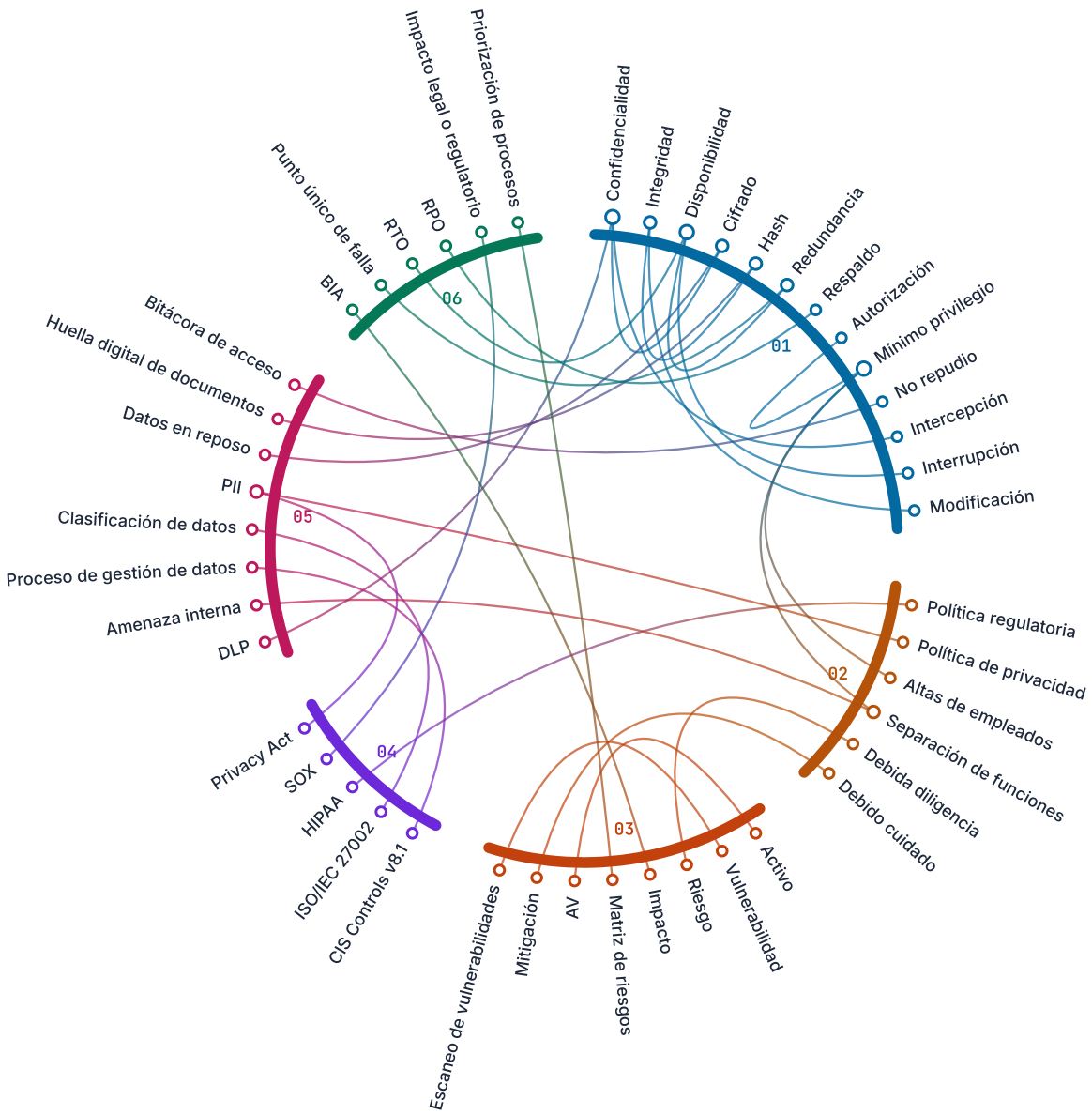
DRP
Parte técnica de la continuidad: cómo levantar servidores, redes y datos después de un desastre.

Pruebas del plan
Simulacros periódicos que validan los tiempos de recuperación y mantienen el BIA actualizado.

CONEXIONES

Red de relaciones entre términos

Los 46 términos que se conectan con otros, agrupados por tema alrededor del círculo.



Cómo leerla

Cada punto es un término y cada línea une dos conceptos relacionados. El color de la línea va del tema de un término al del otro; el tamaño del punto crece con su número de conexiones.

Las líneas que cruzan el centro muestran cómo un tema se apoya en otro; por ejemplo, la confidencialidad se garantiza con cifrado y DLP.

Términos más conectados

Confidencialidad	3 · 01
Disponibilidad	3 · 01
Mínimo privilegio	3 · 01
Integridad	2 · 01
Cifrado	2 · 01
Hash	2 · 01
Redundancia (RAID, clúster)	2 · 01
Separación de funciones	2 · 02

REFERENCIA RÁPIDA

Índice alfabético

El número de color indica el tema; cada tema empieza en la página 3 (tema 01) y sigue en orden.

A

- Aceptar 03
- Activo 03
- ALE (expectativa de pérdida anual) 03
- Altas de empleados 02
- Amenaza 03
- Amenaza interna 05
- ARO (tasa anual de ocurrencia) 03
- Autenticación 01
- Autenticidad 01
- Autorización 01
- AV (valor del activo) 03

B

- Bajas de empleados 02
- BCP 06
- BIA 06
- Bitácora de acceso 05

C

- Capacitación y concientización 02
- Cifrado 01
- Cifrado simétrico / asimétrico 01
- CIS Controls v8.1 04
- Clasificación de datos 05
- Coincidencia de patrones 05
- Confidencialidad 01

D

- Datos en reposo 05
- Datos en tránsito 05
- Datos en uso 05
- Debida diligencia 02
- Debido cuidado 02
- Debido proceso 02
- Defensa en profundidad 01
- Dependencias 06
- Disponibilidad 01
- Disuasión 03
- DLP 05
- DLP de endpoint 05
- DLP de red 05
- DLP en la nube 05
- DRP 06

E

- EF (factor de exposición) 03
- Ejemplo: sismo en el centro de datos 03
- Eliminación segura 05
- Escaneo de vulnerabilidades 03
- Estándar 02
- Evaluación cualitativa 03
- Evaluación cuantitativa 03
- Evitar 03

F

- Fabricación 01
- Flujo de datos 05
- Funciones del núcleo 04

G

- Gestión de cambios 02
- GLBA 04
- Grupos de implementación (IG) 04
- Guía (lineamiento) 02

H

- Hash 01
- Hexada de Parker 01
- HIPAA 04
- Huella digital de documentos 05

I

- Identificación 01
- IG1: higiene cibernética esencial 04
- Impacto 03
- Impacto financiero 06
- Impacto legal o regulatorio 06
- Impacto operativo 06
- Impacto reputacional 06
- Informe BIA 06
- Instalación de software 02
- Integridad 01
- Intercepción 01
- Interrupción 01
- Inventario de datos 05
- ISO/IEC 27001 04
- ISO/IEC 27002 04
- ISO/IEC 38505-1 04

M

- Matriz de riesgos 03
- Mínimo privilegio 01
- Mitigación 03
- Modelo EDM 04
- Modificación 01
- MTBF 06
- MTD (tiempo máximo tolerable) 06
- MTTR 06

N

- NIST CSF 04
- Niveles de implementación 04
- No repudio 01
- Núcleo del marco 04

P

- Pérdida vs. fuga de datos 05
- Perfil actual y objetivo 04
- PII 05
- Política consultiva 02
- Política de contraseñas 02
- Política de privacidad 02
- Política de seguridad 02
- Política regulatoria 02
- Posesión o control 01
- Priorización de procesos 06
- Privacy Act (1974) 04
- Procedimiento 02
- Proceso crítico 06
- Proceso de gestión de datos 05
- Prueba de penetración 03
- Pruebas del plan 06
- Punto único de falla 06

R

- Recolección de información 06
- Redundancia (RAID, clúster) 01
- Registro de riesgos 03
- Respaldo 01
- Respuesta a incidentes 02
- Retención de datos 05
- Riesgo 03
- Rotación de puestos 02
- RPO 06
- RTO 06

S

- Salvaguarda 04
- Seis principios de gobierno 04
- Separación de funciones 02
- Seudonimización y anonimización 05
- SGSI 04
- SLE (expectativa de pérdida única) 03
- SOX 04

T

- Transferir 03

U

- Uso aceptable (AUP) 02
- Uso del correo electrónico 02
- Utilidad 01

V

- Vacaciones obligatorias 02
- Vulnerabilidad 03